

פרק 4 – חומות אש ברשת הבינונית והרחבה

11 שעות עיוני + 2 מעשי · שבועות 10-12

מטרות: ACL סטנדרטי/מורחב · ACL מבוסס זמן · עצירת התקפות ב-ACL · CBAC · ZPF
בבגרות: ACL סטנדרטי (חסימת רשת), מיקום ACL וכיוון in/out, ACL מורחב עם host

לפני שמתחילים – איך תעבורה "עוברת" בנתב? (למי שאין רקע)

חומת אש מחליטה אילו חבילות לעבור. כדי להבין זאת צריך שני מושגים: **כיוון תעבורה** – לכל ממשק (פורט) בנתב יש שני כיוונים: in = חבילות שנכנסות לנתב דרך הפורט, out = חבילות שיוצאות מהנתב דרך הפורט. תמיד חושבים מנקודת המבט של נתב, לא של המשתמש. **סינון לפי כותרת החבילה** – כל חבילה נושאת בכותרת שלה: כתובת מקור, כתובת יעד, סוג פרוטוקול (TCP/UDP/ICMP), ופורט. חומת אש קוראת את הכותרת ומחליטה permit (לעבור) או deny (לחסום). Wildcard mask – דרך לומר "התאם רק חלק מהכתובת". נסביר לעומק בהמשך; רק דעו שזה ההפך ממסכת רשת רגילה: "0 בדוק את הביט הזה", "1 = לא אכפת לי". **אנלוגיה:** חומת אש היא כמו שומר בכניסה לבניין עם רשימה. כל אדם (חבילה) שמגיע – השומר בודק ברשימה (ACL) לפי הזהות שלו (כתובת/פורט), ומחליט להכניס או לא. הרשימה נבדקת הטמל הלעמל, והשומר עוצר בהתאמה הראשונה.

4.1 מהי חומת אש

חומת אש (Firewall) היא מערכת – חומרה, תוכנה או שילוב – שעומדת בין רשתות ברמות אבטחה שונות ומחליטה לפי מדיניות אילו חבילות לעבור ואילו לחסום. המונח מגיע מקיר בטון שמונע התפשטות שריפה בין דירות. המאפיינים: **עמידה בפני התקפות** (היא עצמה מוקשחת), **נקודת מעבר יחידה** (כל התעבורה חייבת לעבור דרכה – אחרת אין טעם), **ואכיפת מדיניות**.

סיפור מהחיים: הקצינו שנפרץ דרך האקווריום (2017)

קצינו בלאס וגאס התקין אקווריום חכם עם חיישן טמפרטורה המחובר לאינטרנט. התוקפים פרצו לחיישן (סיסמת ברירת מחדל), ומכיוון שהאקווריום היה מחובר לאותה רשת של שאר הקצינו – עברו ממנו למסד הנתונים של "השחקנים הגדולים" ושאו 10GB החוצה דרך... החיישן. אם היה ACL אחד שאומר "מהאקווריום מותר רק לשרת הבקרה שלו" – הסיפור היה נגמר בחיישן. חומת אש היא לא רק בין "הפנים" ל"אינטרנט"; היא גם בין חלקי הפנים.

4.2 סוגי חומות אש

סוג	איך זה עובד	יתרונות	חסרונות
סינון חבילות (Packet filtering, stateless) – ACL	בודקת כל חבילה לבד לפי כותרות שכבה 3-4: IP מקור/יעד, פרוטוקול, פורט	מהיר, זול, בכל נתב	לא מבינה "שיחה": כדי לאפשר תשובות חייבים לפתוח פורטים לכיוון פנימה; ניתנת לעקיפה ב-spoofing
Stateful (בדיקת מצב)	שומרת טבלת חיבורים (state table). תעבורה שיוצאת מהפנים נרשמת; רק התשובות שתואמות לרשומה מורשות להיכנס	מאובטחת הרבה יותר, פשוטה להגדרה; הסטנדרט היום (ASA, ZPF, CBAC)	לא מבינה את תוכן האפליקציה; "UDP/ICMP חסרי מצב" מטופלים לפי timeout
Application gateway / Proxy	מסיימת את החיבור, קוראת את תוכן שכבה 7 (HTTP, FTP) ופותחת חיבור חדש ליעד	מבינה תוכן, יכולה לסנן URL, וירוסים	איטית, צריך proxy לכל פרוטוקול
NAT כ"חומת אש"	מסתירה כתובות פנימיות	חינם	אינה חומת אש אמיתית – רק מסתירה

סוג	איך זה עובד	יתרונות	חסרונות
NGFW (דור הבא)	Stateful + זיהוי אפליקציה (Facebook מול YouTube על אותו פורט + 443) + IPS זהות משתמש + בדיקת TLS	מקיפה	יקרה, דורשת כוונן
Host-based (Windows Firewall)	על המחשב עצמו	מגנה גם מפני מחשבים באותה רשת	מנוהלת בנפרד בכל מחשב
Transparent	בשכבה 2 - ללא כתובת IP, "IP שקופה"	מוסיפים בלי לשנות כתובות	

4.3 ACL - רשימות בקרת גישה

ACL (Access Control List) היא רשימה סדורה של משפטי permit/deny שהנתב עובר עליה **מלמעלה למטה** עבור כל חבילה; **בהתאמה הראשונה** הוא מבצע את הפעולה ומפסיק. אם אף שורה לא תואמת - יש deny any **סמוי** (implicit deny) בסוף כל ACL שלוש החוקים האלה מסבירים 90% מהטעויות.

ACL יכולה לשמש לא רק לסינון

גם לזהות תעבורה עבור VPN, route-map, QoS, NAT (פרק 8), ו-class access על קווי VTY. בפרק זה - סינון.

מסכת wildcard - הדבר שתלמידים הכי מתבלבלים בו

ב-ACL לא כתובים subnet mask אלא wildcard mask: ביט 0 = **חייב להתאים**, ביט 1 = **לא אכפת לי**. במסכת רשת רגילה זה הפוך. הדרך המהירה: wildcard mask = 255.255.255.255 - subnet mask.

רשת	Subnet mask	Wildcard	משמעות
192.168.1.0/24	255.255.255.0	0.0.0.255	3 האוקטטים הראשונים חייבים להתאים
172.16.16.0/28	255.255.255.240	0.0.0.15	172.16.16.15-172.16.16.0
10.0.0.0/8	255.0.0.0	0.255.255.255	כל מה שמתחיל ב-10
מארח בודד 10.1.1.7	32/	host = 0.0.0.0 10.1.1.7	הכול חייב להתאים
כל כתובת	-	= 255.255.255.255 any	0.0.0.0 255.255.255.255
רשתות זוגיות 192.168.0.0, .2.0,4.0		192.168.0.0 0.0.254.255	ביט אחרון באוקטט השלישי חייב 0 - טריק לבחינות

בבגרות (חלק א, שאלה 1ט)

"נתונה 135.8.267/26 - מהי ה-subnet mask ומהי ה-wildcard? Subnet: 255.255.255.192 Wildcard: 0.0.0.63. (שימו לב: 267 אינו אוקטט חוקי - טעות בשאלון; מתעלמים).

ACL סטנדרטית - רק לפי מקור

מספרים 1-99 ו-1300-1999 בודקת **רק את כתובת המקור**. לכן ממקמים אותה **קרוב ליעד** - אחרת היא תחסום את המקור מלהגיע גם ליעדים שלא התכוונו אליהם.

```
R1(config)# access-list 10 deny 20.20.20.0 0.0.0.255 24/ חסימת רשת 24 - ! בבגרות שאלה 1ט
R1(config)# access-list 10 permit any (implicit deny) הכול נחסם בלי זה - !
```

```
R1(config)# interface g0/1
R1(config-if)# ip access-group 10 out
```

ACL מורחבת - מקור, יעד, פרוטוקול ופורט

מספרים 199-100 ו-2000-2699 תחביר: access-list N {permit|deny} PROTOCOL SRC [op PORT] DST [op PORT] [established] [log] SRC-WC [op PORT] DST-WC [op PORT] [established] [log] ממקמים קרוב למקור - כדי לא להעביר תעבורה שתיחסם ממילא דרך כל הרשת.

```
! רשת (172.18.1.0/24) IT רשאית ל-DNS ול-DHCP, אך לא ל-10.0.0.190 web - בבגרות חלק א שאלה 3
R1(config)# access-list 101 deny ip 172.18.1.0 0.0.0.255 host 10.0.0.190
R1(config)# access-list 101 permit ip any any
R1(config)# interface g0/0/1
R1(config-if)# ip access-group 101 in
! דוגמאות לפורטים
R1(config)# access-list 110 permit tcp 192.168.1.0 0.0.0.255 any eq 80
R1(config)# access-list 110 permit tcp 192.168.1.0 0.0.0.255 any eq 443
R1(config)# access-list 110 permit udp 192.168.1.0 0.0.0.255 host 8.8.8.8 eq 53
R1(config)# access-list 110 deny icmp any any echo ! חסימת ping
R1(config)# access-list 110 permit tcp any any established state- (דלוק) - ! רק תשובות (ACK/RST)
ful לעניים"
R1(config)# access-list 110 deny ip any any log ! רשום מה נחסם (רק בסוף) !
```

אופרטורים: eq שווה, neq, gt, lt, range. פורטים ניתן לכתוב בשם (eq www, eq ftp, eq do - , eq (main).

ACL בשם (Named) - הדרך המומלצת

```
R1(config)# ip access-list extended BLOCK-WEB
R1(config-ext-nacl)# remark IT may not reach the web server
R1(config-ext-nacl)# 10 deny tcp 172.18.1.0 0.0.0.255 host 10.0.0.190 eq 80
R1(config-ext-nacl)# 20 permit ip any any
R1(config-ext-nacl)# exit
R1(config)# interface g0/0/1
R1(config-if)# ip access-group BLOCK-WEB in
! עריכה: מוחקים/מוסיפים שורה לפי מספר רצף - בלי למחוק את כל הרשימה
R1(config)# ip access-list extended BLOCK-WEB
R1(config-ext-nacl)# no 10
R1(config-ext-nacl)# 15 deny tcp 172.18.1.0 0.0.0.255 host 10.0.0.190 eq 443
! סטנדרטית בשם - זה מה שמופיע בבגרות (config-std-nacl)
R1(config)# ip access-list standard BLOCK_LAN2
R1(config-std-nacl)# deny 192.168.2.0 0.0.0.255
R1(config-std-nacl)# permit any
```

כיוון: in או out?

הכיוון הוא מנקודת מבטו של הנתב על ממשק מסוים. in = חבילות שנכנסות לנתב דרך הממשק הזה (לפני ניתוב). out = חבילות שיוצאות מהנתב דרך הממשק הזה (אחרי ניתוב). ACL אחת לכל ממשק, לכל כיוון, לכל פרוטוקול.

בבגרות (שאלה 7) - הדוגמה המושלמת

R1 עם שלוש רשתות: G0/1→192.168.1.0, G0/2→192.168.2.0, Re→192.168.3.0 (stricted חוסמים את 192.168.2.0 ל-192.168.3.0 בלבד. ACL סטנדרטית ⇒ קרוב ליעד ⇒ G0/2. כיוון: התעבורה יוצאת מהנתב לרשת 3 ⇒ out. סדר: 192.168.2.0 deny ואז permit any. תשובה

2. אם היינו שמים in על G0/1 - רשת 2 הייתה נחסמת גם לרשת 1 ולאינטרנט. אם permit any היה ראשון - ה-deny לעולם לא היה מגיע.

טעויות נפוצות ב-ACL

- שוכחים permit בסוף ⇒ הכול נחסם. תלמידים מגדירים ""X deny ומתפללים שאין אינטרנט.
- סדר הפוך - שורה כללית לפני ספציפית.
- wildcard כ-255.255.255.0 (subnet mask במקום 0.0.0.255).
- ACL מוגדרת אך לא הוחלה על ממשק (ip access-group) - ב-show ip interface רואים "Out-going access list is not set".
- ACL סטנדרטית שממוקמת קרוב למקור - חוסמת הרבה יותר מהמתוכנן.
- ACL על VTY: לא ip access-group אלא in access-class 10 תחת line vty.
- ה-ACL לא בודקת תעבורה שהנתב עצמו יוצר (ping) מהנתב - רק תעבורה שעוברת דרכו.

ורפיקציה

```
R1# show access-lists ! כולל מונה התאמות (matches) לכל שורה - הכלי הכי טוב לדיבוג
R1# show ip access-lists 101
R1# show ip interface g0/1 ! איזו ACL מוחלת ובאיזה כיוון
R1# show running-config | section access-list
R1# clear access-list counters
```

ACL 4.4 מורכבות: מבוססות זמן, דינמיות ורפלקסיביות

Time-based ACL

מאפשרת כלל שתקף רק בזמנים מסוימים. דורש שעון נכון (NTP) - פרק 2).

```
R1(config)# time-range WORK-HOURS
R1(config-time-range)# periodic weekdays 8:00 to 17:00
R1(config-time-range)# exit
R1(config)# access-list 120 permit tcp 192.168.1.0 0.0.0.255 any eq 80 time-range WORK-
HOURS
R1(config)# access-list 120 deny ip any any
periodic Monday Wednesday 9:00 to 12:00 / absolute start 08:00 1 Jan 2026 end 17:00 31 Jan
2026 ! אפשרויות:
```

Dynamic ACL (Lock-and-Key)

המשתמש מבצע Telnet/SSH לנתב ומזדהה; רק אז נפתחת לו דלת זמנית דרך הנתב. "מנעול ומפתח".

```
R1(config)# username student password 0 pass
R1(config)# access-list 101 permit tcp any host 10.0.0.1 eq telnet
R1(config)# access-list 101 dynamic OPEN-DOOR timeout 15 permit ip any any
R1(config)# interface g0/0
R1(config-if)# ip access-group 101 in
R1(config)# line vty 0 4
R1(config-line)# login local
R1(config-line)# autocmd access-enable host timeout 5
```

Reflexive ACL

"מראה": כשתעבורה יוצאת החוצה, הנתב יוצר אוטומטית שורה זמנית שמאפשרת רק את התשובה (IP)/(פורט הפוכים) להיכנס. זה מנגנון stateful פשוט ב-ACL, ועדיף על established כי עובד גם ל-UDP ו-ICMP.

```

R1(config)# ip access-list extended OUTBOUND
R1(config-ext-nacl)# permit tcp any any reflect TCP-TRAFFIC
R1(config-ext-nacl)# permit udp any any reflect UDP-TRAFFIC
R1(config)# ip access-list extended INBOUND
R1(config-ext-nacl)# evaluate TCP-TRAFFIC
R1(config-ext-nacl)# evaluate UDP-TRAFFIC
R1(config-ext-nacl)# deny ip any any
R1(config)# interface s0/0/0
R1(config-if)# ip access-group OUTBOUND out
R1(config-if)# ip access-group INBOUND in

```

4.5 עצירת התקפות בעזרת ACL

Anti-spoofing – מה לחסום בכניסה מהאינטרנט (ingress)

```

R1(config)# ip access-list extended ANTI-SP00F
! כתובות פרטיות (RFC 1918) לא אמורות להגיע מהאינטרנט – מישור מזיף
R1(config-ext-nacl)# deny ip 10.0.0.0 0.255.255.255 any
R1(config-ext-nacl)# deny ip 172.16.0.0 0.15.255.255 any
R1(config-ext-nacl)# deny ip 192.168.0.0 0.0.255.255 any
! הרשת שלנו כמקור מבחץ – זיוף ודאי
R1(config-ext-nacl)# deny ip 203.0.113.0 0.0.0.255 any
R1(config-ext-nacl)# deny ip 127.0.0.0 0.255.255.255 any loopback !
R1(config-ext-nacl)# deny ip 0.0.0.0 0.255.255.255 any
R1(config-ext-nacl)# deny ip 224.0.0.0 15.255.255.255 any multicast !
! ICMP – לאפשר רק מה שצריך, לחסום echo מבחץ (נגד ping sweep ו-Smurf)
R1(config-ext-nacl)# permit icmp any any echo-reply
R1(config-ext-nacl)# permit icmp any any unreachable
R1(config-ext-nacl)# permit icmp any any time-exceeded traceroute !
R1(config-ext-nacl)# deny icmp any any
! שירותי ניהול לא נגישים מבחץ
R1(config-ext-nacl)# deny tcp any any eq 23
R1(config-ext-nacl)# deny udp any any eq 161
! רק תשובות ל-TCP שהפנים פתח + שירותי DMZ
R1(config-ext-nacl)# permit tcp any any established
R1(config-ext-nacl)# permit tcp any host 203.0.113.10 eq 80
R1(config-ext-nacl)# permit tcp any host 203.0.113.10 eq 443
R1(config-ext-nacl)# deny ip any any log
R1(config)# interface g0/0
R1(config-if)# ip access-group ANTI-SP00F in

```

Egress filtering – גם ביציאה: לאפשר רק את כתובות המקור שלנו; כך הרשת שלנו לא תשמש ל-DDoS עם כתובות מזויפות.

4.6 CBAC Context-Based Access Control – (חומת אש "קלאסית" ב-IOS)

ACL היא stateless. CBAC (נקראת גם Classic Firewall) מוסיפה מצב: היא בוחנת (inspect) תעבורה שיוצאת מהפנים, זוכרת את השיחה בטבלת state, ופותחת אוטומטית וזמנית חור ב-ACL הנכנסת לתשובות בלבד. היא גם מבינה פרוטוקולים עם פורטים דינמיים (FTP active) ומגנה מ-TCP intercept SYN flood (like).

```

! ACL 1 שחוסמת הכול מבחץ (התשובות ייפתחו על ידי CBAC)
R1(config)# ip access-list extended OUTSIDE-IN

```

```

R1(config-ext-nacl)# permit icmp any any echo-reply
R1(config-ext-nacl)# deny ip any any
R1(config)# interface s0/0/0
R1(config-if)# ip access-group OUTSIDE-IN in
2. כלל בדיקה
R1(config)# ip inspect name FW tcp
R1(config)# ip inspect name FW udp
R1(config)# ip inspect name FW http
R1(config)# ip inspect name FW ftp
3. החלה בכיוון שבו התעבורה "מתחילה" - יוצאת החוצה
R1(config)# interface s0/0/0
R1(config-if)# ip inspect FW out
R1# show ip inspect sessions
R1# show ip inspect config

```

CBAC היא "מבוססת ממשק": ככל שיש יותר ממשקים, ההגדרה מסתבכת. לכן סייקו החליפה אותה ב-ZPF.

Zone-Based Policy Firewall – 4.7 ZPF

הגישה המודרנית ב-IOS: במקום לחשוב על ממשקים, מגדירים **אזורים** (zones) ומדיניות **בין זוגות אזורים** (zone-pair), בכיוון אחד. חוקים:

- ממשק שייך לאזור אחד לכל היותר.
- תעבורה בין ממשקים **באותו אזור** – מותרת תמיד.
- תעבורה בין ממשק באזור לממשק שלא באזור – **נחסמת**.
- תעבורה בין שני אזורים – **נחסמת כברירת מחדל**, אלא אם יש zone-pair עם מדיניות.
- אזור מיוחד self = הנתב עצמו (תעבורה אל הנתב וממנו – SSH, OSPF, ברירת המחדל ל-self: הכול מותר).

שלוש פעולות

פעולה	משמעות
inspect	בדיקה stateful – מאפשר את התעבורה ואת התשובות חזרה אוטומטית. זה מה שרוצים כמעט תמיד.
pass	מאפשר את התעבורה בכיוון הזה בלבד, בלי מעקב (כמו permit ב-ACL). לתשובה צריך pass בזוג ההפוך.
drop	חוסם (ברירת מחדל, אפשר להוסיף log).

ההגדרה – C3PL (Cisco Common Classification Policy Language) בחמישה שלבים

```

1. ! אזורים
R1(config)# zone security INSIDE
R1(config)# zone security OUTSIDE
2. class-map (איזו תעבורה = match-any; מספיק תנאי אחד; match-all = כולם)
R1(config)# class-map type inspect match-any WEB-DNS
R1(config-cmap)# match protocol http
R1(config-cmap)# match protocol https
R1(config-cmap)# match protocol dns
R1(config-cmap)# match protocol icmp
R1(config-cmap)# exit
! (אפשר גם match access-group 101 לשלב ACL)
3. policy-map – מה עושים עם התעבורה

```

```

R1(config)# policy-map type inspect IN-T0-OUT
R1(config-pmap)# class type inspect WEB-DNS
R1(config-pmap-c)# inspect
R1(config-pmap-c)# exit
R1(config-pmap)# class class-default ! כל השאר
R1(config-pmap-c)# drop log
R1(config-pmap-c)# exit
zone-pair 4. - מקור, יעד, ומדיניות
R1(config)# zone-pair security IN-OUT source INSIDE destination OUTSIDE
R1(config-sec-zone-pair)# service-policy type inspect IN-T0-OUT
R1(config-sec-zone-pair)# exit
! 5. שיוך ממשקים לאזורים - ברגע זה החסימה מתחילה!
R1(config)# interface g0/1
R1(config-if)# zone-member security INSIDE
R1(config)# interface s0/0/0
R1(config-if)# zone-member security OUTSIDE
! וריפיקציה
R1# show zone security
R1# show zone-pair security
R1# show policy-map type inspect zone-pair IN-OUT sessions
R1# show class-map type inspect

```

שאלת תלמיד: "הגדרתי OUTSIDE→INSIDE עם inspect. איך התשובות חוזרות, הרי אין zone-pair "INSIDE→OUTSIDE"

זה בדיוק מה ש-inspect עושה: הנתב רושם את השיחה בטבלת state, וכשמגיעה תשובה מ-OUTSIDE שתואמת לשיחה קיימת - היא עוברת, בלי צורך ב-zone-pair הפוך. תעבורה חדשה מ-OUTSIDE (למשל מישהו מבחוץ מנסה SSH למחשב פנימי) - נחסמת. אם היינו משתמשים ב-pass במקום inspect, התשובות היו נחסמות.

שאלת תלמיד: "אחרי שהגדרתי ZPF, אני לא מצליח לעשות SSH לנתב מבחוץ / OSPF נפל"

תעבורה אל הנתב עצמו שייכת לאזור self. ברירת המחדל ל-self היא permit, אז SSH אמור לעבוד. אם הגדרתם zone-pair שמערב self עם מדיניות - עכשיו רק מה שהוגדר עובר. יש להוסיף class ל-SSH/OSPF עם pass/inspect. גם בדקו ש-CBAC (ip inspect) לא מוגדרת על אותו ממשק - אסור לשלב.

4.8 תכנון חומת אש ברשת - שיטות עבודה

- DMZ: שלושה אזורים - INSIDE, DMZ, OUTSIDE. מדיניות: INSIDE→DMZ inspect; DMZ→DMZ inspect; OUTSIDE→DMZ inspect; DMZ→OUTSIDE inspect; OUTSIDE→OUTSIDE inspect; (אם שרת ה-web נפרץ - התוקף לא ממשיך פנימה). INSIDE→OUTSIDE - כלום.
- **מינימום הרשאות** (least privilege): מתחילים מ-deny all ופותחים רק מה שיש לו הצדקה עסקית.
- **תיעוד**: כל שורת ACL עם remark; מי ביקש, מתי, למה.
- **ביקורת**: פעם ברבעון - show access-lists; שורות עם 0 matches - כנראה מיותרות.
- Logging - Log על deny בסוף, אבל לא על permit (עומס).

סיפור מהחיים: 32 מיליון שורות ACL

בחברת ביטוח גדולה, בדיקת ביקורת מצאה חומת אש עם 8,000 כללים, מתוכם 3,200 שלא התאימו לאף חבילה במשך שנה - "כללים זומבי" שאף אחד לא העז למחוק כי "אולי משהו ישבר". בין הזומבים: כלל מ-2009 שפתח RDP לכל האינטרנט לשרת שכבר לא קיים - אך הכתובת שלו הוקצתה מחדש לשרת HR. הלקח: חומת אש שלא מתחזקים היא לא חומת אש; והשוואת מוני matches היא לא רק לדיבוג.

4.9 מדריך פקודות מרוכז - פרק 4

פקודה	תפקיד
access-list 1-99 {permit deny} SRC WC	ACL סטנדרטית ממוספרת
access-list 100-199 {permit deny} PROTO SRC WC [eq P] DST WC [eq P]	ACL מורחבת ממוספרת
ip access-list {standard extended} NAME	ACL בשם, עם מספרי רצף
ip access-group N {in out} (ממשק)	החלת ACL
(line vty) access-class N in	ACL על גישת ניהול
any / host A	קיצורים ל- 0.0.0.0 / 255.255.255.255 wildcard
,time-range ,log ,established dynamic ,evaluate/reflect	מילות מפתח מתקדמות
show ip interface , show access-lists	ורפיקציה
ip inspect + ip inspect name N PROTO N out	CBAC
class-map type → zone security → policy-map type inspect → inspect zone-member → zone-pair security security	ZPF, בסדר הזה
show , show zone-pair security policy-map type inspect zone-pair sessions	ורפיקציה ZPF

4.10 תרגילים לתלמידים

תרגיל 1 - wildcard

כתבו את ה-wildcard: א. 192.168.10.0/25 ב. 10.10.0.0/16 ג. 172.16.4.0/22 ד. המארח 8.8.8.8 ה. כל הכתובות 192.168.0.0 עד 192.168.7.255

א. 0.0.0.127 ב. 0.0.255.255 ג. 0.0.3.255 ד. 0.0.0.0 (host 8.8.8.8) ה. 192.168.0.0 0.0.7.255

תרגיל 2 - מה עובר?

access-list 105 permit tcp 192.168.1.0 0.0.0.255 any eq 443 access-list 105 deny tcp 192.168.1.0 0.0.0.255 any eq 80 access-list 105 permit udp any host 8.8.8.8 eq 53 interface g0/0 (LAN 192.168.1.0/24) ip access-group 105 in מ-192.168.1.20: א. HTTPS ל-1.1.1.1 ב. HTTP ל-1.1.1.1 ג. DNS ל-8.8.8.8 ד. DNS ל-1.1.1.1 ה. ping ל-1.1.1.1 ו. SSH לנתב עצמו

א. עובר (שורה 1). ב. נחסם (שורה 2). ג. עובר (3). ד. נחסם. (implicit deny). ה. נחסם (implicit deny) - אין שורה ל-. (icmp). ו. נחסם - גם תעבורה אל הנתב עוברת דרך ACL נכנסת. תלמידים רבים חושבים שרק "מה שכתוב deny נחסם - זו הנקודה.

תרגיל 3 - תכנון ACL

נתב עם G0/0 → רשת תלמידים G0/1, 10.1.0.0/16 → רשת מורים G0/2, 10.2.0.0/16, שרתים 10.3.0.0/24 (שרת ציונים 10.3.0.10, שרת קבצים. 10.3.0.20) דרישות: תלמידים לא ניגשים לשרת הציונים אך כן לשרת הקבצים; מורים ניגשים להכול; תלמידים לא רשאים ל-Telnet/SSH לשום מקום. כתבו ACL מורחבת בשם, ובחרו ממשק וכיוון.

ip access-list extended STUDENTS deny ip 10.1.0.0 0.0.255.255 host 10.3.0.10 deny tcp

10.1.0.0 0.0.255.255 any eq 22 deny tcp 10.1.0.0 0.0.255.255 any eq 23 permit ip any
 מורים לא G0/0 in. ⇒ קרוב למקור ⇒ any interface g0/0 ip access-group STUDENTS in
 מופיעים - permit any (הם ממילא לא נכנסים ב-G0/0).

תרגיל 4 – ZPF

ציירו טבלה של אזורים (INSIDE / DMZ / OUTSIDE וכתבו לכל זוג 6) כיוונים) איזו מדיניות תגדירו ומדוע.

DMZ: inspect http,→DMZ: inspect. OUT→IN (הכול/רשימת פרוטוקולים).
zone-pair (drop). IN→OUT (ל- match access-group עם ה-IP של השרתים).
OUT: inspect dns, ntp, http→DMZ. "שרת נפרץ לא ממשיך פנימה".
DDoS (עדכוניים) בלבד – ולא הכול, כדי ששרת נפרץ לא ישמש ל-.

4.11 שאלות בסגנון בגרות

שאלה 1

איזו פקודה חוסמת את המארח 10.5.5.5 בלבד ב-ACL סטנדרטית?

```
access-list 10 deny 2. access-list 10 deny 10.5.5.5 255.255.255.255 1.
access-list 10 4. access-list 100 deny 10.5.5.5 0.0.0.0 3. host 10.5.5.5
deny 10.5.5.0 0.0.0.255
```

2. (1 - wildcard של 3; any - מספר של מורחבת ותחביר חסר; 4 - חוסם רשת שלמה.)

שאלה 2

מנהל הגדיר ACL עם שורה אחת: `access-list 20 deny 192.168.5.0 0.0.0.255` והחיל אותה. אף אחד לא מצליח לצאת. מדוע?

```
.access-list 20 permit any חסר implicit deny any
```

שאלה 3

היכן נכון למקם ACL מורחבת - קרוב למקור או ליעד? ומדוע?

קרוב למקור - היא מזהה בדיוק את התעבורה (מקור+יעד+פורט), ולכן אפשר לחסום אותה מוקדם ולא לבזבז רוחב פס. סטנדרטית - קרוב ליעד, כי היא בודקת רק מקור ותחסום יותר מדי אם תמוקם קרוב אליו.

שאלה 4

ב-ZPF, ממשיק G0/0 באזור INSIDE וממשיק G0/1 לא שויך לאף אזור. מה יקרה לתעבורה ביניהם?

תיחסם. ממשק באזור לא מתקשר עם ממשק שאינו באזור.

שאלה 5

מה ההבדל בין הפעולות inspect ו-pass ב-ZPF?

inspect - מעקב stateful, התשובות מורשות אוטומטית. pass - מעבר בכיוון אחד בלבד ללא מעקב; לתשובות נדרש pass בזוג ההפוך.

שאלה 6

השלימו: R1(config)# access-list 101 deny ip _____ host _____
R1(config-if)# _____ · fig)# access-list 101 permit _____
IT כר שמשמשי (172.18.1.0/16 לפי הטבלה) יקבלו DNS ו-DHCP אך לא. WEB (10.0.0.190)

```
ip · ip any any · 10.0.0.190 · (0.0.0.255 :24/ לפי 172.18.1.0 0.0.255.255  
access-group 101 in
```

4.12 מעבדה (2 שעות) – ACL ו-ZPF ב-Packet Tracer

1. ACL: בנו את הטופולוגיה משאלה 7 בבגרות R1 עם 3 רשתות). הגדירו את BLOCK_LAN2 והחילו out על G0/2. בדקו ping מרשת 2 לרשת 3 (נכשל) ולרשת 1 (מצליח). הריצו show access-lists וראו את המונים עולים.
2. הזיזו את אותה ACL ל-G0/1 in. מה נשבר? (רשת 2 מאבדת הכול). הסבירו.
3. ACL מורחבת: אפשרו לרשת 2 רק HTTP לשרת ברשת 3 וחסמו ping בדקו בדפדפן של ה-PC.
4. ZPF: טופולוגיה R1-INSIDE(PC) - R1-OUTSIDE(Server). הגדירו class-map, zone-pairs, http+icmp, inspect, zone-pair IN-OUT. דפדפן לשרת עובד, ping עובד. מהשרת: ping ל-PC נכשל. הריצו show policy-map type inspect zone-pair sessions ותוך כדי גלישה.
5. החליפו inspect ב-pass. מה קרה לגלישה? הסבירו בעזרת מושג ה-state.

בנק שאלות שתלמידים שואלים – ותשובות מוכנות

שאלות נפוצות בפרק חומות האש וה-ACL, עם תשובות מוכנות.

הבנת ACL

ש: "הגדרתי רק שורת deny אחת ופתאום שום דבר לא עובד. למה?"

ת: בגלל ה-deny any הסמוי בסוף כל ACL. ברגע שיש ACL, כל מה שלא הותר במפורש – נחסם. חייבים להוסיף permit מפורש למה שרוצים לאפשר, אחרת הכול נחסם.

ש: "למה wildcard הפוך ממסכת רשת רגילה? זה מבלבל."

ת: כי הוא עונה על שאלה אחרת. מסכת רשת אומרת "איזה חלק הוא הרשת". Wildcard אומרת ל-ACL אילו ביטים לבדוק: 0 = חייב להתאים, 1 = לא אכפת לי. טריק: wildcard = 255.255.255.255 פחות מסכת הרשת.

ש: "איך אני יודע אם ה-ACL בכלל עובד?"

ת: show access-lists – ליד כל שורה יש תומאתה הנומ (matches). אם שולחים תעבורה והמונה לא עולה, ה-ACL לא נתפס (כנראה לא הוחל על ממשק, או בכיוון הלא נכון). זה כלי הדיבוג מספר 1.

ש: "למה סטנדרטי קרוב ליעד, ומורחב קרוב למקור?"

ת: סטנדרטי בודק רוקמ קר, אז אם נמקם אותו קרוב למקור הוא יחסום את המקור מלהגיע לכל יעד – יותר מדי. לכן קרוב ליעד. מורחב מזהה בדיוק מקור + יעד + פורט, אז אפשר לחסום מוקדם (קרוב למקור) בלי לפגוע בתעבורה אחרת.

ש: "מה ההבדל בין in ל-out? אני מתבלבל."

ת: תמיד מנקודת המבט של הנתב: in = נכנס לנתב דרך הממשק (לפני שהנתב מנתב). out = יוצא מהנתב דרך הממשק (אחרי הניתוב). ציירו נתב עם חצים – זה מתבהר מיד.

ש: "האם ACL חוסם גם תעבורה שהנתב עצמו שולח (למשל ping מהנתב)?"

ת: לא. ACL בודק תעבורה שקרד תרבוה הנתב, לא תעבורה שהנתב עצמו יוצר. לכן ping מהנתב עצמו יעבור גם אם יש ACL חוסם.

חומות אש מתקדמות

ש: "מה ההבדל בין חומת אש stateless ל-stateful?"

ת: ACL Stateless (רגיל) בודקת כל חבילה בנפרד – לא "זוכרת" שיחות, אז צריך לפתוח ידנית פורטים לתשובות. Stateful (ZPF/CBAC) זוכרת שיחות שיצאו, ומאפשרת רק את התשובות התואמות להיכנס – בטוח וקל בהרבה.

ש: "ב-ZPF הגדרתי OUTSIDE→INSIDE עם inspect. איך התשובות חוזרות אם אין zone-pair בכיוון ההפוך?"

ת: זה בדיוק מה ש-inspect עושה: הנתב זוכר את השיחה בטבלת state, וכשמגיעה תשובה תואמת – היא עוברת אוטומטית, בלי צורך ב-zone-pair הפוך. תעבורה השדח מבחוץ עדיין נחסמת.

ש: "מה ההבדל בין inspect ל-pass ב-ZPF?"

ת: inspect עוקב אחרי השיחה ומאפשר תשובות אוטומטיות. (stateful) pass רק מעביר בכיוון אחד בלי מעקב - לתשובה צריך pass נפרד בכיוון ההפוך. כמעט תמיד רוצים inspect.

ש: "מה זה DMZ ולמה צריך אותו?"

ת: אזור "מפורז" בין הרשת הפנימית לאינטרנט, שבו יושבים השרתים הציבוריים (אתר, מייל). הרעיון: אם שרת ב-DMZ נפרץ, התוקף עדיין לא נמצא ברשת הפנימית - יש חומת אש נוספת בין ה-DMZ לפנים.

ש: "אם יש לי חומת אש, אני מוגן לגמרי?"

ת: לא. חומת אש בודקת כתובות ופורטים, אבל התקפה יכולה להגיע בפורט שפתחת (SQL injection) דרך פורט (80) לכן צריך גם IPS (פרק 5) שבודק תוכן, וגם הגנות בשכבה 2 (פרק 6). (להגנה לעומק).

מילון מונחים - הגדרות

הגדרות תמציתיות של המונחים המרכזיים בפרק. שימושי גם כדף עזר לבחינה.

מונח	הגדרה
חומת אש (Firewall)	מערכת שמסננת תעבורה בין רשתות לפי מדיניות (permit/deny).
ACL (Access Control List)	רשימה סדורה של כללי permit/deny; נסרקת מלמעלה למטה, עצירה בהתאמה ראשונה.
implicit deny	חסימה סמויה של כל מה שלא הותר במפורש, בסוף כל ACL.
Stateless	סינון כל חבילה בנפרד, ללא זכירת שיחות (ACL רגיל).
Stateful	זכירת שיחות שיצאו והתרת התשובות התואמות (ZPF/CBAC/ASA). בלבד.
ACL סטנדרטי	מספרים 1-99; בודק רק כתובת מקור; ממקמים קרוב ליעד.
ACL מורחב	מספרים 100-199; בודק מקור, יעד, פרוטוקול ופורט; ממקמים קרוב למקור.
Wildcard mask	מסכה הפוכה למסכת רשת: 0=חייב להתאים, 1=לא אכפת. $255.255.255.255 =$ פחות המסכה.
in / out	כיוון החלת ACL מנקודת מבט הנתב: נכנס לממשק (in) או יוצא ממנו (out).
host / any	קיצורי wildcard: host=כתובת בודדת (0.0.0.0), any=כל כתובת (255.255.255.255).
established	מילת מפתח ב-ACL המתירה רק חבילות תשובה של חיבור TCP קיים.
Time-based ACL	כלל ACL שתקף רק בזמנים מוגדרים (דורש שעון NTP).
Reflexive ACL	'ACL מראה' שיוצר אוטומטית התר זמנית לתשובות של תעבורה שיצאה.
Dynamic ACL (Lock-and-Key)	דלת זמנית שנפתחת רק לאחר שהמשתמש מזדהה בנתב.
CBAC	חומת אש stateful קלאסית ב-IOS; בוחנת תעבורה יוצאת ופותחת התר לתשובות.
ZPF (Zone-Based Firewall)	חומת אש מודרנית ב-IOS מבוססת אזורים ומדיניות בין זוגות אזורים.
Zone / Zone-pair	אזור אבטחה שממשקים משויכים אליו; מדיניות מוגדרת בין זוג אזורים בכיוון אחד.
inspect / pass / drop	פעולות ZPF: inspect=stateful (תשובות אוטומטיות), pass=מעבר חד-כיווני, drop=חסימה.
DMZ	אזור מפורז לשרתים ציבוריים, מבודד מהרשת הפנימית.

מונח	הגדרה
Anti-spoofing	חסימת כתובות מקור מזויפות (פרטיות/פנימיות) בכניסה מהאינטרנט.